

Clinic & Diagnostic Lab DPDPA Starter Checklist

Your clinic doesn't just treat patients — it collects, stores and shares health data every day. Work through these ten areas to bring patient intake, report sharing, recipient verification, staff/vendor access and old-record retention under DPDPA-ready control.

Patient Reports

Prescriptions

Health Data

WhatsApp Sharing

Lab Software

Reception Access

Home Collection

Doctor Referrals

Insurance / TPA

Retention

How to use this: tick what you already do, and turn the unticked boxes into your next actions. Start with recipient verification, report sharing and staff access — they remove the most risk for the least effort.

1 Patient registration & intake

- ☐ Define approved channels for collecting patient details, prescriptions and ID proof.
- ☐ Reduce scattered intake through WhatsApp, phone calls and loose paper forms.
- ☐ Show a short notice at registration: what you collect, why, who sees it, how long you keep it.
- ☐ Collect only the patient data the visit/test actually needs.
- ☐ Keep one primary patient record so you always know what you hold.

2 Prescription & lab-report handling

- ☐ Store reports, prescriptions and images in access-controlled systems, not open folders or inboxes.
- ☐ Avoid keeping duplicate copies of reports across WhatsApp, email and devices.
- ☐ Treat fertility, pregnancy, mental-health and chronic-condition data as especially sensitive.
- ☐ Restrict who can open sensitive reports to staff who need them for the task.
- ☐ Label and organise reports so the right one reaches the right patient.

3 WhatsApp / email report sharing

- ☐ Verify the patient's number/email before sending any report.
- ☐ Prefer a secure portal or password-protected file for sensitive reports.
- ☐ Don't forward reports through personal WhatsApp/email accounts of staff.
- ☐ Keep a record of which report was sent to whom, and when.
- ☐ Delete report copies from chats/inboxes once delivered.

4 Family-member / caregiver sharing

- ☐ Get the patient's consent before sending reports to a family member or caregiver.
- ☐ Confirm the recipient's identity — don't assume the registered number is the patient.
- ☐ Be especially careful with sensitive results (fertility, mental health, infectious disease).
- ☐ Record who the patient authorised to receive their reports.
- ☐ Stop sharing with a contact when the patient withdraws consent.

5 Reception, billing & lab-staff access

- ☐ Give reception, billing, lab and support staff access only to what they need.
- ☐ Avoid shared logins — give each person their own account, with MFA.
- ☐ Review who can access patient records at least twice a year.
- ☐ Brief every joiner on patient-data confidentiality and DPDPA basics.
- ☐ Log access where your software supports it.

6 Clinic software / LIS / HIS access

- ☐ List the clinic software, LIS, HIS and imaging tools that hold patient data.
- ☐ Turn on role-based access and MFA in each system.
- ☐ Remove access the same day a staff member or vendor leaves.
- ☐ Check whether your software vendor stores or backs up patient data, and where.
- ☐ Put data-handling terms (a DPA) in place with each platform.

7 Outsourced labs & home sample collection

- ☐ List every outsourced/referral lab and home-collection partner that handles patient data.
- ☐ Confirm what each partner stores, for how long, and who can access it.
- ☐ Give home-collection agents only the patient details they need for the visit.
- ☐ Use agreements that require partners to protect and delete patient data.
- ☐ Track samples and reports end-to-end so nothing is lost or mis-delivered.

8 Insurance / TPA / corporate sharing

- ☐ Share patient data with insurers/TPAs/corporates only with authorisation or a clear purpose.
- ☐ Tell patients when their reports will be shared with an insurer or employer.
- ☐ Don't share reports simply because a partner or referring doctor asks.
- ☐ Share the minimum needed for the claim or referral.
- ☐ Keep a record of what was shared, with whom, and why.

9 Old report & prescription retention

- ☐ Set a retention period for reports, prescriptions and images by record type.
- ☐ Balance medical-record obligations with 'delete when no longer needed'.
- ☐ Don't keep patient records indefinitely by default.
- ☐ Schedule a periodic review to archive or delete records past their period.
- ☐ Write retention rules down so the whole team applies them consistently.

10 Wrong-report sharing & breach response

- ☐ Write a one-page plan: who to call and what to do first if a report reaches the wrong person.
- ☐ Know how to quickly lock a compromised WhatsApp account, email or lab-software login.
- ☐ Keep a contact list (IT, software vendor, and a way to reach affected patients).
- ☐ Be ready to notify the Data Protection Board and affected patients as required.
- ☐ After any incident, record what happened and what you changed.